



海南师范大学

本科生毕业论文

论文题目：融合溯源反制的轻量化诱捕型蜜罐系统设计与实现

姓 名：钟文智

学 号：2024021045

专 业：计算机科学与技术

年 级：2024

学 院：人工智能学院

完成日期：2026 年 4 月

指导教师：黄鹏

本科生毕业设计原创性声明

本人声明所呈交的毕业设计是本人在导师指导下进行的研究工作及取得的研究成果，除了文中特别加以标注和致谢的地方外，本设计中没有抄袭他人研究成果和伪造数据等行为。与我一同工作的同志对本研究所做的任何贡献均已在设计中作了明确的说明并表示谢意。

论文作者签名：_____ 日期：_____

本科生毕业设计使用授权声明

海南师范大学有权保留并向国家有关部门或机构送交毕业设计的复印件和磁盘，允许毕业设计被查阅和借阅。本人授权海南师范大学可以将本毕业设计的全部或部分内容编入有关数据库进行检索，可以采用影印、缩印或其他复印手段保存、汇编毕业设计。

论文作者签名：_____ 日期： 20 年 月 日

指导教师签名：_____ 日期： 20 年 月 日

目 录

目 录	i
第 1 章 绪论	1
1.1 研究背景及意义.....	1
1.1.1 研究背景.....	1
1.1.2 研究意义.....	1
1.2 国内外研究现状.....	1
第 2 章 系统相关技术介绍.....	3
2.1 GIN 后端框架	3
2.2 前端框架	3
2.3 MySQL 数据库.....	4
第 3 章 系统分析与设计.....	5
3.1 需求分析	5
3.1.1 管理后台功能分析.....	5
3.1.2 前端展示功能分析.....	5
3.1.3 系统安全性分析.....	5
3.2 系统概要设计.....	6
3.2.1 系统总体设计.....	6
3.2.2 系统功能模块设计.....	7
3.3 系统数据库概要设计.....	8
3.3.1 模型设计.....	8
3.3.2 数据库表设计.....	9

第 4 章 系统详细实现过程.....	11
4.1 系统开发环境.....	11
4.2 前端展示模块.....	11
4.2.1 假登录页面.....	11
4.2.2 真登录页面.....	13
4.3 后台管理模块.....	14
4.3.1 攻击者信息汇总.....	14
4.3.2 蜜罐插件管理.....	15
4.3.3 插件功能演示.....	17
4.3.4 XGPT 威胁分析智能体	22
4.3.5 系统设置.....	23
第 5 章 系统测试	25
5.1 测试目的	25
5.2 后台管理功能测试.....	25
5.3 性能测试	26
5.4 测试结果	28
第 6 章 结论	29
参考文献	30
致 谢	31

融合溯源反制的轻量化诱捕型蜜罐系统设计与实现

作者：钟文智 指导教师：黄鹏
(海南师范大学人工智能学院，海口 571158)

摘要：面对当前网络攻击日益复杂的安全形势，本文设计并实现了一个基于 Go 语言和 Gin 框架的轻量级诱捕 Web 蜜罐系统。该系统通过模拟企业管理系统的登录界面搭建了一个欺骗环境，可以部署在企业的内外网生产环境中。用于主动捕获攻击行为、收集攻击数据和分析攻击方式，为网络安全防护提供实用的威胁情报支持。该系统具有攻击者信息管理、蜜罐日志和事件管理、插件动态配置等核心功能。威胁分析模块集成了 DeepSeek API，可以实现自动化的威胁检测和深度行为分析，有效提高了攻击检测和溯源的效率。

关键词：Gin；网络安全；溯源反制；网络攻击；网络蜜罐

Design and Implementation of Lightweight Trapping Honeypot System Integrating Traceability Countermeasure

Author: ZhongWen Zhi Supervisor: HuangPeng
(School of Artificial Intelligence, Hainan Normal University, Haikou 571158)

Absrtact: In the face of the increasingly complex security situation of current network attacks, this paper designs and implements a lightweight trapping Web honeypot system based on Go language and Gin framework. The system builds a spoofing environment by simulating the login interface of the enterprise management system, which can be deployed in the internal and external network production environment of the enterprise. It is used to actively trap attack behavior, collect attack data and analyze attack methods, and provide practical threat intelligence support for network security protection. The system has core capabilities such as attacker information management, honeypot log and event management, and plug-in dynamic configuration. The threat analysis module integrates DeepSeek API, which can realize automatic threat detection and deep behavior analysis, and effectively improve the efficiency of attack detection and traceability.

Keywords : Gin ; network security ; tracing back to the source ; network attack ; network honeypo

第 1 章 绪论

1.1 研究背景及意义

1.1.1 研究背景

互联网技术发展得很快，这带来了越来越严重的网络安全问题。有统计说，全球每年因为网络攻击造成的经济损失能达到数千亿美元，所以网络安全现在成了全世界都关注的重点。像防火墙、入侵检测系统这些传统的防御手段当然能起到一些保护作用，但它们本质上是被动的，对于新出现的攻击类型往往很难做到主动发现和分析。蜜罐技术就不太一样了，它是一种主动的防御思路。它的做法是模拟出看起来真实的系统和服务，目的是把攻击者吸引过来进行攻击。这样一来就能收集到攻击信息、分析他们的行为模式、搞清楚他们用的技术和工具，最终为整体的网络安全防御提供有价值的情报支持。而 Web 蜜罐呢，它是蜜罐技术里专门针对 Web 应用攻击的一个分支，在捕获和分析针对网页的攻击行为方面效果比较明显。

1.1.2 研究意义

蜜罐可以给企业更多的操作空间来应对网络攻击，而不是一味地被动防御，也可以主动掌握。通过积极部署蜜罐，企业可以准确捕获攻击数据，分析攻击行为，实时感知网络安全态势。不仅为防御策略的制定提供了科学依据，减轻了真实业务系统的安全压力，而且依托收集到的情报进行技术研究和人员培训，不断提升企业的整体安全防护能力。使企业从“被动抵御”转向“主动洞察、提前预防”，有效拓宽了网络安全防护的边界，为企业网络安全筑起了主动防御的屏障，进一步保障了企业核心数据和业务系统的稳定和安全^{[2][3][4]}。

1.2 国内外研究现状

当前，Web 轻量化蜜罐正处在一个转变期，它不再只是简单的诱捕工具，而是朝着智能化、体系化的主动防御基础设施这个方向在演进。关于轻量化的定义，学界和业界基本达成了共识：它以中低交互性作为核心特征，能够支持容器化部署和快速上线，单个实例的资源占用非常低，同时具备基础的攻击诱捕与情报收集功能。无论是国内还是国外的研究或产品开发，其实都围绕着快速搭建、低资源消耗和高隐蔽性这几个核心需求来展开。不过它们的发展路径确实存在明显的不同：国外那边更侧重于通用场景下的标准化工作以及智能化技术的突破；国内研究与实践更多聚焦于政企、能源、工控等关键信息基础设施场景，注重满足合规性要求，适应实际攻防对抗环境

[1][5]

Web 轻量级蜜罐领域已经有一些比较成熟的工具，比如国外的一些蜜罐工具：OpenCanary、Beelzebub AI Honeypot 等。Open Canary 是一个低资源的模块化的标杆，是轻量级蜜罐的奠基性项目。它扩展简单，支持 HTTP / HTTPS、SSH、FTP 等 20 多个服务模拟。用户可以根据场景需求灵活的打开或关闭模块。其模块化的设计思想为后续轻量级蜜罐的开发提供了重要的参考。它仍然是低资源场景部署的首选工具之一。Beelzebub AI Honeypot 蜜罐是近年来新兴的人工智能驱动的轻量级蜜罐项目。用户可以在不编写复杂代码的情况下配置仿真场景，通过生成式人工智能模拟高交互蜜罐的行为。

国内的一些蜜罐项目有 HFish、DecoyMini 吉星（智能仿真与攻击诱捕系统）、谛听（D-Sensor）伪装欺骗系统等。HFish 是目前国内在开源蜜罐生态的标杆支持多协议中低交互仿真，跨平台支持，场景化定制能力强^{[10][11]}。DecoyMini 采用插件化的仿真模板，支持一键导入云端仿真模板库快速部署多样化的安全可控仿真服务^[13]；支持虚拟 IP 与动态端口绑定，将网络内空闲 IP 资源绑定到仿真环境，大幅提高攻击诱捕能力；资源占用极低，优势是极致轻量化、适合大规模集群部署。D-Sensor 谛听是长亭科技的一款商用产品拥有动态诱捕、流量重定向、智学习仿真等技术，构建了攻击诱捕、溯源、干扰和阻断的主动防御能力是国内中高交互轻量化蜜罐领域的标杆产品^[12]。

未来研究趋势，蜜罐技术的研究将向以下方向发展：

(1) 智能化：借助人工智能，蜜罐的自动配置、攻击检测与分析得以实现，这提升了其效率和准确性。

(2) 云化：将蜜罐部署在云环境中，可以依托这个云平台的弹性扩容、网络隔离与资源调度能力还有能配合云厂商的 WAF 能力，可以实现更灵活的快速创建、销毁与扩容蜜罐节点还可以批量管理统计日志、流量审计、集中检测溯源分析。

(3) 容器化：可以将蜜罐部署到 docker 上之后迁移再次部署过程变得更快，同时实现了更好的隔离效果，这对提升其安全性与运行可靠性，由于 docker 容器都是独立沙箱即使被 RCE 了，攻击行为也会变限制在单个容器内，难以进一步利用横向生态到宿主机或内网其他的设备，有效降低了安全风险扩散的可能性。

(4) 威胁情报共享：此外构建一个能够共享蜜罐威胁情报的平台，让不同组织之间可以交换这些信息，对于提升整体的网络安全防御水平而言是重要的。

第 2 章 系统相关技术介绍

2.1 GIN 后端框架

Gin 这个框架，是用 Go 语言写出来的一个 HTTP Web 框架，性能方面表现得很不错。它的 API 设计上，和 Martini 那个框架有点像，但实际跑起来要快得多。这主要归功于它用了 httprouter，据说速度能提升到四十倍那么多。Gin 专为构建 REST API、Web 应用和微服务而设计，适用于对速度和开发效率有要求的场景^[9]。

Gin 的主要特性：

- (1) 零分配路由：极高的内存效率路由，无堆内存分配。
- (2) 高性能：基准测试显示其速度优于其他 Go Web 框架。
- (3) 中间件支持：可扩展的中间件系统，支持认证、日志记录、CORS 等。
- (4) 不会崩溃：内置恢复中间件可防止 panic 导致服务器崩溃。
- (5) JSON 验证：自动请求/响应 JSON 绑定和验证。
- (6) 路由分组：组织相关路由并应用公共中间件。
- (7) 错误管理：集中式错误处理和日志记录。
- (8) 内置渲染：支持 JSON、XML、HTML 模板等。
- (9) 可扩展：拥有大量社区中间件和插件的生态系统^[16]。

2.2 前端框架

本系统前端部分直接使用 HTML、CSS 和 JavaScript 进行构建，没有引入那些复杂的前端框架。这么做有几个明显的好处，比如代码本身比较轻量，所以加载起来速度会快一些。而且因为用的是这些基础技术，它在各种浏览器里都能跑得比较顺畅，兼容性这方面不用担心。还有一个点是定制起来方便，想改界面或者调整功能的时候能很快动手，毕竟结构相对简单清晰。不依赖外部框架也意味着系统整体更简洁，减少了不必要的复杂性和对外部组件的依赖。具体到这套系统里面，前端主要就是负责登录页面还有管理员后台页面的呈现工作，用来把蜜罐相关的功能界面和数据展示给用户看。

2.3 MySQL 数据库

MySQL 是一种关系型数据库管理系统，它具有以下特点：

- (1) 可靠性高-MySQL 是一种成熟的数据库管理系统，具有高可靠性和稳定性。
- (2) 性能优异-在性能方面它同样出色，能够有效应对大规模数据处理和并发访问的需求。
- (3) 易于使用-MySQL 的 SQL 语法简单易懂，易于学习和使用。
- (4) 开源免费-MySQL 是一种开源免费的数据库管理系统，降低了系统的成本。
- (5) 支持多种存储引擎-MySQL 该系统还支持多种存储引擎，比如 InnoDB 和 MyISAM 等，这允许用户根据具体应用场景来灵活选择最合适的存储方案^[15]。

在本系统中，MySQL 数据库被用于存储攻击者信息、蜜罐日志、蜜罐事件和插件信息等数据。

第 3 章 系统分析与设计

3.1 需求分析

进行需求分析，首先得把已有的工作业务过程拆开来看，找出里面存在的问题。所以呢，在分析了现有管理流程的基础上，我们还得接着去琢磨它的功能和性能到底怎么样。

3.1.1 管理后台功能分析

(1) 攻击者信息管理：收集和管理攻击者的信息，包括用户名、密码、IP 地址、用户代理等。

(2) 蜜罐事件管理：收集和管理蜜罐的事件信息，包括事件类型、数据、IP 地址、用户代理等。

(3) 插件管理：管理蜜罐的插件，包括创建、更新、删除和启用/禁用插件。

(4) 系统设置：管理系统的配置，包括 API 密钥、管理员账户、数据库连接等。

(5) 威胁分析：通过集成威胁分析智能体，提供高级威胁检测和分析能力。

3.1.2 前端展示功能分析

(1) 登录页面：模拟企业管理系统的登录页面，吸引攻击者尝试登录。

(2) 管理员仪表盘：展示攻击者信息、蜜罐日志、蜜罐事件等数据，方便管理员查看和分析。

(3) 插件管理界面：展示和管理蜜罐的插件，包括插件的列表、详情、编辑和状态管理。

(4) 威胁分析界面：提供交互式威胁分析界面，支持查询威胁情报和分析攻击模式。

(5) 系统设置界面：管理系统的配置，包括 API 密钥、管理员账户、数据库连接等。

3.1.3 系统安全性分析

(1) 认证与授权：管理员接口使用 Basic Auth 认证，确保只有授权用户能够访问管理员功能还可以防测绘收录后台。

(2) 数据安全：所有攻击数据存储安全的数据库中，支持定期备份数据。

(3) 蜜罐欺骗性：返回虚假的登录失败响应，隐藏真实的系统信息，模拟真实系统的行为和错误信息。

(4) 自我保护：蜜罐系统自身需要具备一定的安全防护能力，防止被攻击者利用作为攻击跳板。

(5) 数据隐私：保护收集到的攻击数据的隐私，避免敏感信息泄露。

3.2 系统概要设计

这个系统概述的设计，主要是为了能把这个系统的要求理解得更全面和深入一些，然后去确定整个体系到底该怎么实现。它要对体系的总体架构还有功能做详细的说明和策划，这里头就包括了模块怎么划分、功能有哪些以及数据处理这些内容。

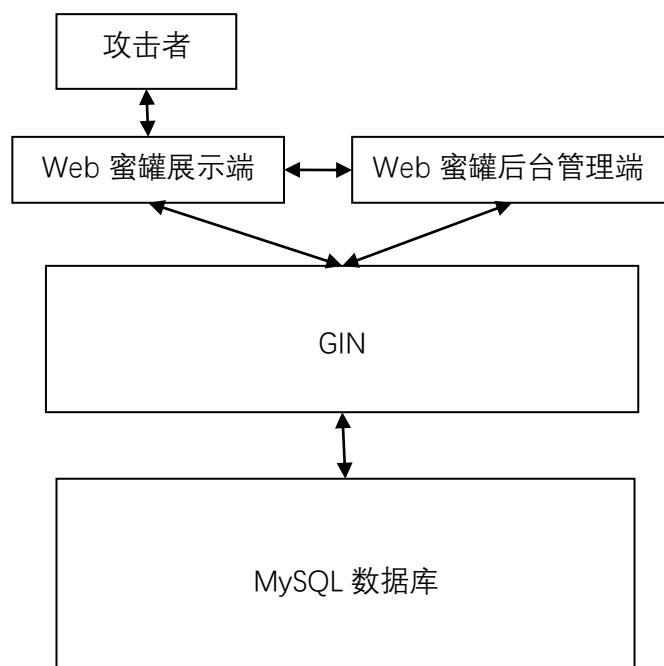
3.2.1 系统总体设计

本系统采用了分层架构，包括前端层、后端层和数据层三个部分：

(1) 前端层：负责用户界面的展示，包括登录页面和管理员后台页面。

(2) 后端层：负责处理业务逻辑，包括蜜罐功能、管理员功能和威胁分析功能。

(3) 数据层：负责数据的存储和管理，包括攻击者信息、蜜罐日志、蜜罐事件和插件信息等，如图 3.1 所示。



如图 3.1 系统总体架构

系统的工作流程如下：

- (1) 攻击者访问蜜罐的登录页面，输入用户名和密码。
- (2) 蜜罐后端接收登录请求，记录攻击者的信息，返回虚假的登录失败响应。
- (3) 管理员通过管理员后台查看和分析攻击数据。
- (4) 管理员可以管理蜜罐的插件，配置系统设置，使用威胁分析智能体分析攻击数据。

3.2.2 系统功能模块设计

在开发系统之前，得先做全面的需求分析，然后根据实际情况去调整 and 选择。基于这个分析结果，整个系统大致可以分成几个部分来看。攻击者信息汇总、插件模块、XGPT 威胁分析模块等等

本系统包含以下功能模块：

- (1) 蜜罐核心模块：处理登录请求，记录攻击者信息，返回虚假的登录失败响应。
- (2) 数据收集模块：收集攻击者的信息、蜜罐的日志和事件。
- (3) 插件系统模块：管理蜜罐的插件，支持插件的创建、更新、删除和启用/禁用。
- (4) 管理员后台模块：提供管理员界面，用于查看和分析攻击数据，管理插件和系统设置。
- (5) 威胁分析模块：集成威胁分析智能体，提供高级威胁检测和分析能力。

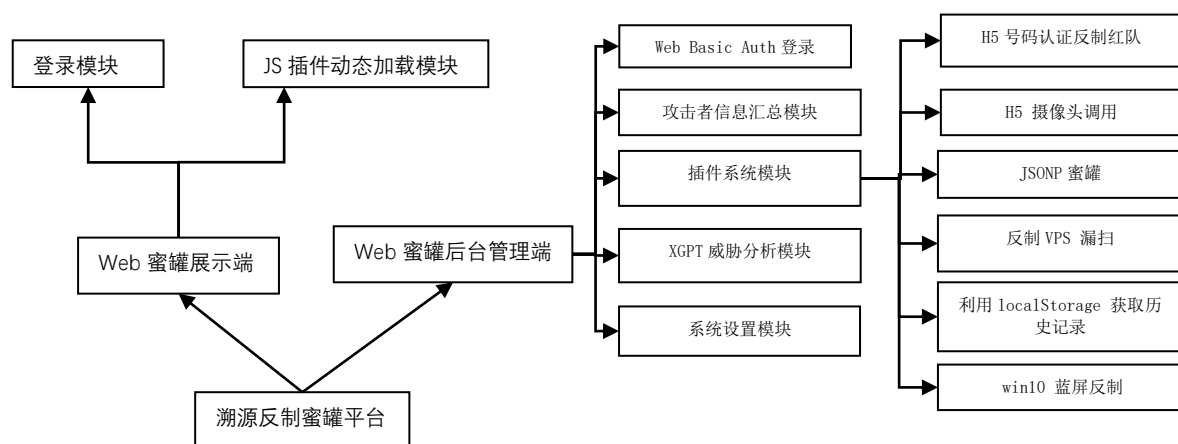


图 3.2 系统功能模块设计

3.3 系统数据库概要设计

3.3.1 模型设计

E-R 图能够将系统的实体、属性、实体之间的关系直观形象的画出来，能让人一眼看到系统的核心结构，通过这个图模块之前的数据关系一目了然，整个系统价格不会混乱结构更清晰。图 3.3 就是系统的 E-R 图。

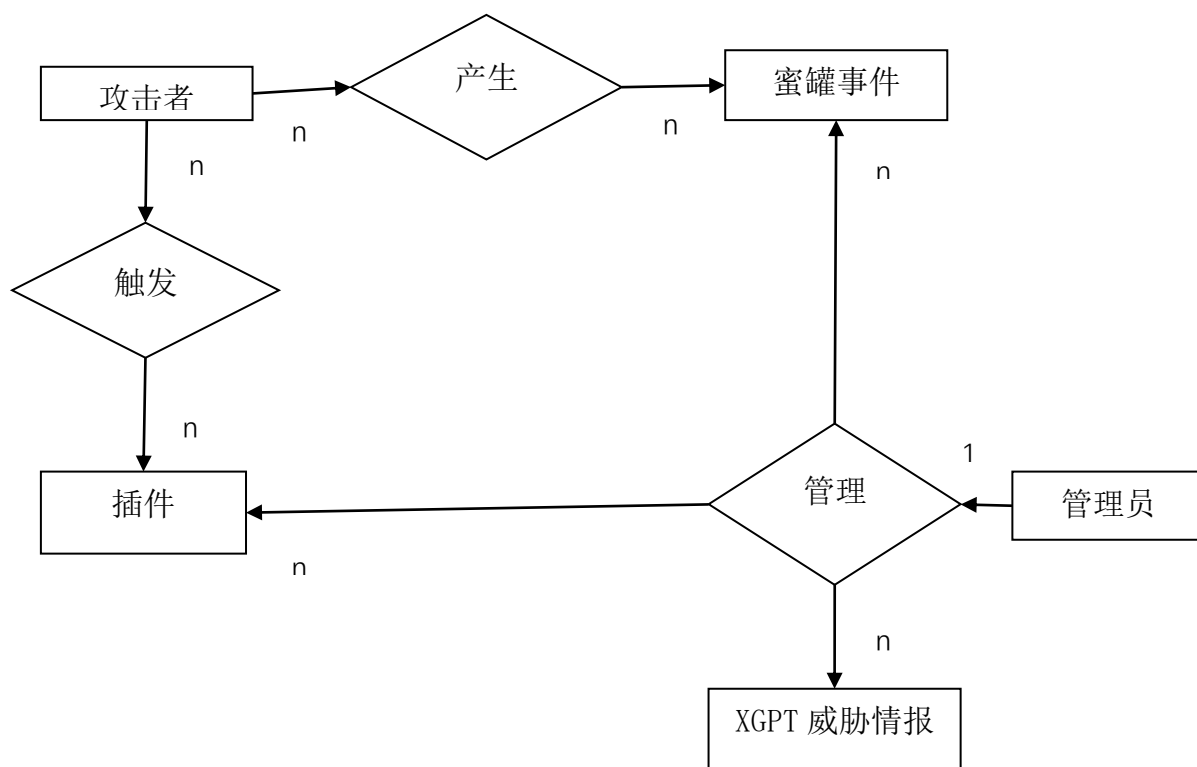


图 3.3 系统 E-R 图

本系统包含以下数据模型：

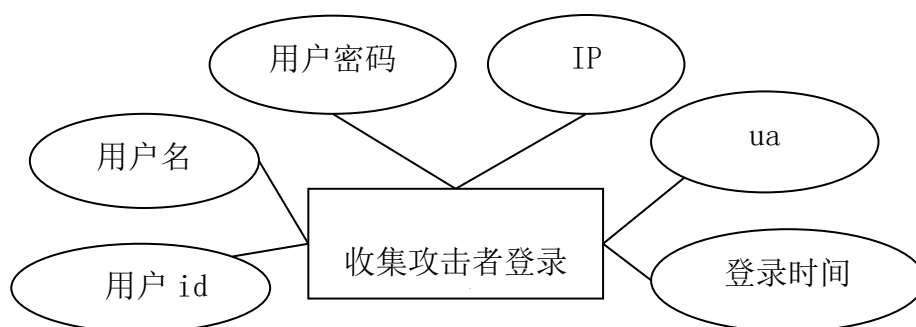


图 3.4 attackers 表设计

(1) Attacker（攻击者信息）：存储攻击者的用户名、密码、IP 地址、用户代理和时间戳等信息。

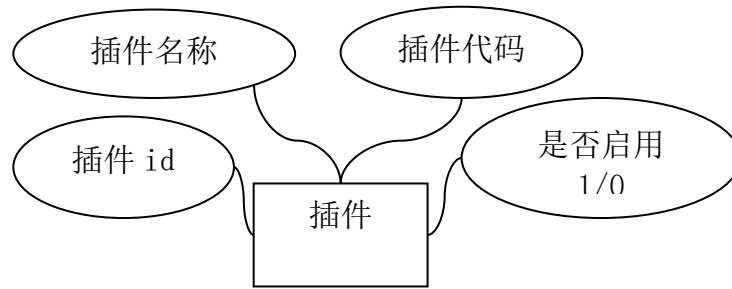


图 3.5 plugins 表设计

(2) Plugin (蜜罐插件)：存储插件的 ID、名称、代码和启用状态等信息。

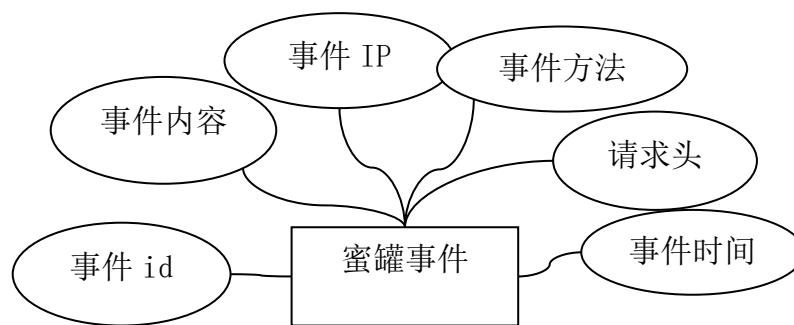


图 3.6 webhook_requests 表设计

(3) webhook_requests 表：存储蜜罐日志信息，包含 id、data、method、ip、headers 和 timestamp 字段。

3.3.2 数据库表设计

设计完成 ER 图模型与关系分析后把 ER 图里的实体内容转为数据库表结构，本系统的 3 个核心数据表，attacks 存储攻击者溯源信息、Plugin 存储蜜罐插件、webhook_requests 存储蜜罐事件，以下是系统中部分数据库表的结构设计：

(1) 攻击者信息表 attackers: 表 3.1 存储攻击者在蜜罐页面提交的信息

表 3.1 attackers 攻击者信息表

字段名	数据类型	长度	说明
id	int(11)	11	主键, 自增 ID
username	varchar(255)	255	攻击者输入的用户名
password	varchar(255)	255	攻击者输入的密码
ip	varchar(45)	45	攻击者 IP 地址
ua	Text	-	攻击者客户端 UA 信息
timestamp	datetime	-	攻击发生时间

(2) 系统插件表 plugins: 表 3.2 存储插件名称代码和状态

表 3.2 plugins 系统插件表

字段名	数据类型	长度	说明
id	Varchar	36	插件唯一标识 UUID
name	Varchar	255	插件名称
code	Text	-	插件执行代码
enabled	tinyint	1	插件启用状态 (1 启用, 0 禁用)

(3) 蜜罐事件表 webhook_requests: 表 3.3 存储插件提交过来的蜜罐事件

表 3.3 webhook_requests 蜜罐请求记录表

字段名	数据类型	长度	说明
id	int(11)	11	主键, 自增 ID
data	text	-	请求体数据
ip	varchar(45)	45	请求来源 IP
method	varchar(10)	10	HTTP 请求方法
headers	text	-	请求头信息
timestamp	datetime	-	请求时间

第 4 章 系统详细实现过程

完成了系统分析还有系统设计后，对软件的各个关键核心模块的具体实现思路进行讲解并给出相应的程序开发方案， 本系统采用真假两个后台整体划分成两大模块本文分别进行详细说明并展示部分功能界面效果与关键实现代码。

4.1 系统开发环境

- (1) 开发语言和框架：主要开发语言为 Go 1.16+、HTML、CSS、JavaScript。使用的框架 GIN
- (2) 数据库：MySQL 5.7+
- (3) 开发工具：GoLand 2024.3.2.1
- (4) 操作系统：Windows10 家庭版操作系统。
- (5) 测试环境：Google、Microsoft Edge 浏览器。

4.2 前端展示模块

蜜罐接口列表如 4.1 表所示：

表 4.1 前台蜜罐接口列表

方法	路径	功能	认证
POST	/honeypot/login	处理登录请求并记录攻击者信息	否
GET	/plugins/active	获取激活的插件	否

4.2.1 假登录页面

登录页面模拟了企业管理系统的界面，如图 4.1 所示。它包含用户名输入框和密码输入框，用于接收用户凭证。登录按钮负责提交请求。除此之外页面还集成了一个动态加载的蜜罐插件，这个插件的主要作用是收集攻击者的更多信息。



图 4.1 假登录页面

动态加载蜜罐的实现代码如下：

```
<script src="/js/login.js"></script>
<!-- 蜜罐插件将在这里动态插入 -->
```

蜜罐系统前端插件的动态加载。具体来说，就是等页面加载完了之后，它会去后端把那些已经激活的插件列表给拉取过来。然后呢，把这些插件的代码动态地注入到当前页面里去执行。整个过程里还得处理可能出现的请求异常问题，这样才能保证整个系统那种插件化的架构能够正常跑起来。

```
01 定义函数 loadHoneypotPlugins()
02      1. 调用 fetch 接口/plugins/active，获取激活的插件列表
03      2. 校验接口响应状态，异常则抛出错误
04      3. 解析响应为 JSON 数据
05      4. 获取页面插件容器，清空原有内容
06      5. 遍历插件列表：
07          5.1 创建 script 标签
08          5.2 写入插件代码
09          5.3 将 script 标签插入页面，执行插件
10      6 捕获异常，打印错误日志
11 监听 DOMContentLoaded 事件，页面加载完成后执行 loadHoneypotPlugins()
```

伪代码 4.2.1 接口拉取已激活蜜罐插件核心流程

4.2.2 真登录页面

访问：/admin/dashboard 输入密码登录后跳转到后台首页。

使用 Web Basic Auth 登录方式对抗资产测绘技术收录后台，如图 4.2 所示。

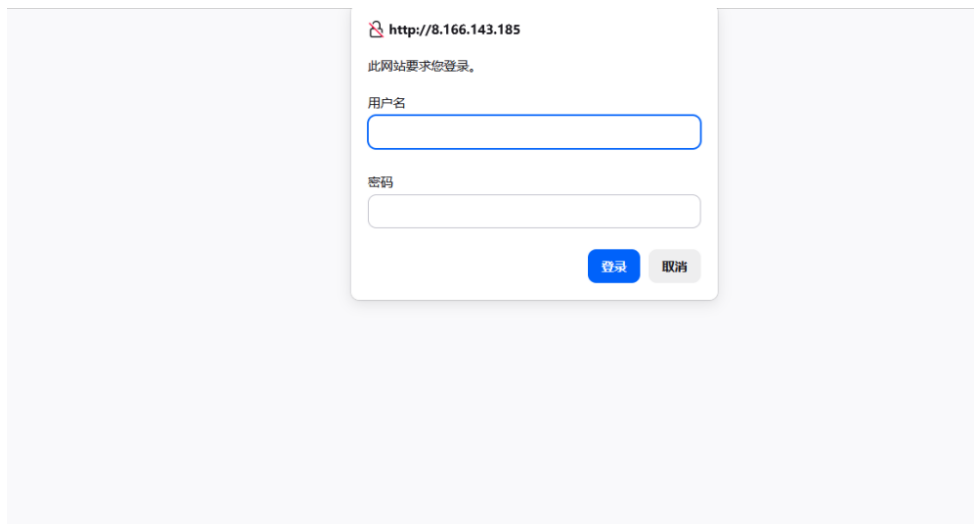


图 4.2 真登录页面

```
01 // 管理员路由组配置
02 1. 创建/admin 前缀的路由分组 adminGroup
03 2. 为 adminGroup 添加 Basic Auth 认证中间件，所有/admin 路由需身份验证
04 3. 配置 GET /admin/dashboard 路由，返回./public/dashboard.html 静态页
05 面
06
07 // Basic Auth 认证中间件实现
08 1. 定义 getAdminUsername 函数：
09     1.1 从环境变量 ADMIN_USERNAME 读取用户名
10     1.2 若为空，设置默认值"admin"
11     1.3 返回用户名
12 2. 定义 getAdminPassword 函数：
13     2.1 从环境变量 ADMIN_PASSWORD 读取密码
14     2.2 若为空，设置默认值"admin123"
15     2.3 返回密码
16 3. 定义 BasicAuthMiddleware 函数：
17     3.1 调用 Gin 框架的 BasicAuth 方法
18     3.2 传入通过 getAdminUsername 和 getAdminPassword 获取的账号密码
    3.3 返回认证中间件实例
```

伪代码 4.2.2 Basic Auth 认证中间件实现核心流程

4.3 后台管理模块

后台管理员接口列表如 4.2 表所示：

表 4.2 后台管理员接口列表

方法	路径	功能	认证
GET	/admin/dashboard	管理员仪表盘页面	是
GET	/admin/api/attackers	获取攻击者信息	是
GET	/admin/api/plugins	获取所有插件	是
DELETE	/admin/api/plugins/:pluginID	删除插件	是
POST	/admin/api/plugins/	创建插件	是
PUT	/admin/api/plugins/	更新插件	是
PATCH	/admin/api/plugins/	更新插件状态	是
GET	/admin/api/webhook/requests	接收蜜罐事件	是

4.3.1 攻击者信息汇总

管理员仪表盘展示攻击者信息、蜜罐日志、蜜罐事件等数据，包含以下元素：如图 4.3 所示

- (1) 攻击者信息表格：展示所有捕获的攻击记录。
- (2) 数据刷新按钮：用于刷新数据。
- (3) 数据导出按钮：用于导出数据。
- (4) 侧边导航栏：支持页面切换。



序号	账号	密码	IP地址	请求头UA	时间
10	admin	admin	127.0.0.1	Mozilla/5.0 (Windows NT 10.0; Win64; x64...	2025/12/11 19:22:06
9	123	123	127.0.0.1	Mozilla/5.0 (Windows NT 10.0; Win64; x64...	2025/12/11 18:16:36
8	admin	admin	::1	Mozilla/5.0 (Windows NT 10.0; Win64; x64...	2025/12/11 18:16:15
1	admin	password123	192.168.1.100	Mozilla/5.0 (Windows NT 10.0; Win64; x64...	2025/12/11 00:51:18
2	root	toor	10.0.0.50	Mozilla/5.0 (X11; Linux x86_64) AppleWebKit...	2025/12/10 23:51:18
3	user	pass	172.16.0.75	Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_...	2025/12/10 22:51:18

图 4.3 攻击者信息汇总页面

后台仪表盘提供攻击者画像的全量数据。具体来说，就是通过从 mysql 数据库拉取数据并以 JSON 格式返回来实现的，它支撑了整个攻击态势的可视化呈现。

- 1

定义接口处理函数 GetAttackersProfile，接收 Gin 上下文 c
- 2

1. 调用 storage.GetAllAttackers()，从存储层获取全部攻击者画像数据
- 3

2. 调用 c.JSON()，以 HTTP 200 状态码，将数据以 JSON 格式返回给前端

伪代码 4.3.1 查询 attackers 表展示数据实现核心流程

4.3.2 蜜罐插件管理

蜜罐插件是该系统核心功能之一，可以给蜜罐系统添加扩展功能模块，可以根据需要安装不同的插件来增强蜜罐的能力。

管理员创建一个“H5 号码认证反制红队”-》插件在登录页面自动运行-》攻击者访问时，插件收集通过运营商的接口认证服务获取攻击者的部分手机号-》这些信息保存到数据库，供溯源提供更多反击面。

通过插件系统，您可以不断优化蜜罐的欺骗性和数据收集能力，更好地应对各种网络攻击威胁，如图 4.4 蜜罐插件管理页面所示。



搜索插件: 名称或描述	添加插件
H5号码认证反制红队 H5号码认证反制红队 - 蜜罐插件 H5 摄像头调用 H5 摄像头调用 - 蜜罐插件 JSONP蜜罐 JSONP蜜罐 - 蜜罐插件 反制VPS 漏洞基于无头浏览器技术 反制VPS 漏洞基于无头浏览器技术 - 蜜罐插件 利用localStorage 获取历史记录 利用localStorage 获取历史记录 - 蜜罐插件 win10 蓝屏反制 win10 蓝屏反制 - 蜜罐插件	H5号码认证反制红队 描述: H5号码认证反制红队 - 蜜罐插件 创建者: admin 创建时间: 2026/4/9 01:21:18 最后修改: 2026/4/9 01:21:18 状态: 未激活 自定义JS代码 编辑 // 动态加载脚本 function loadscript(src, callback) { var script = document.createElement('script'); script.type = 'text/javascript'; script.charset = 'utf-8'; script.src = src; script.onload = callback; } 激活插件 停用插件 删除插件

图 4.4 蜜罐插件管理页面

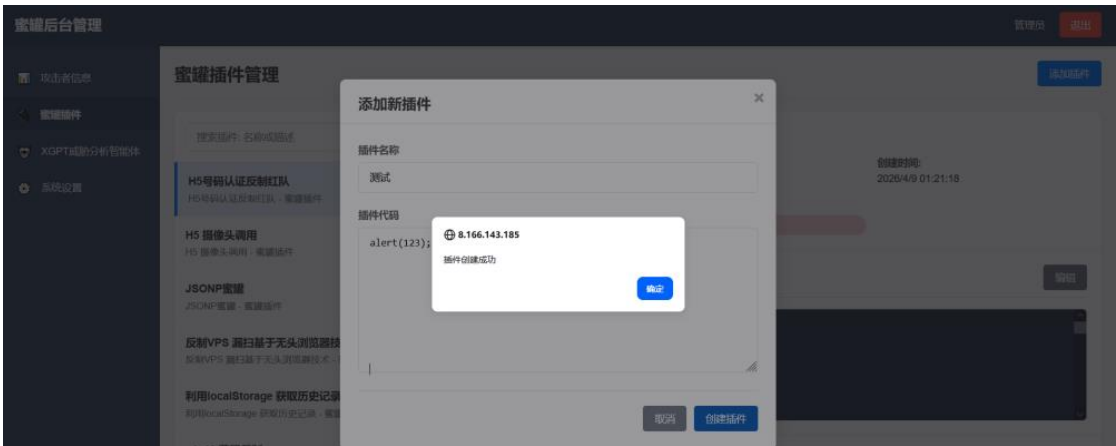


图 4.5 蜜罐插件管理页面

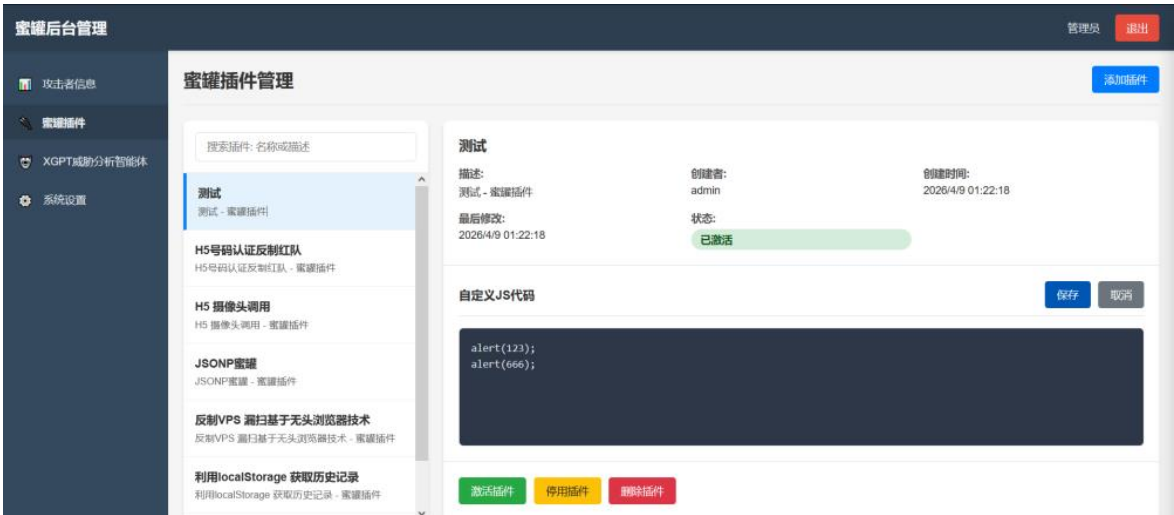


图 4.6 蜜罐插件管理页面

蜜罐系统插件的创建接口。具体来说，接收前端提交的插件配置的代码，自动生成 ID 并将插件写入存储到数据库。

```
1 定义接口处理函数 CreatePlugin，接收 Gin 上下文 c
2    1. 声明 Plugin 类型变量 plugin，用于接收请求数据
3    2. 调用 c.ShouldBindJSON 绑定请求体到 plugin，校验数据合法性
4    3. 若校验失败，返回 HTTP 400 错误响应并终止流程
5    4. 为 plugin 生成唯一 UUID 作为 ID
6    5. 调用 storage.CreatePlugin，将插件数据写入存储
7    6. 返回 HTTP 201 成功响应，提示插件创建完成
```

伪代码 4.3.2 蜜罐插件管理创建插件实现核心流程

4.3.3 插件功能演示

插件一：利用 localStorage 获取历史记录

场景假设：当攻击者做 web 渗透没用使用隐私模式时，利用 localStorage 判断是否访问过，高敏感网站来判断是否为网络安全从业人员。



图 4.7 利用 localStorage 获取历史记录

蜜罐后台已启用该插件，攻击者在某开启隐私模式下访问蜜罐“企业管理系统”。

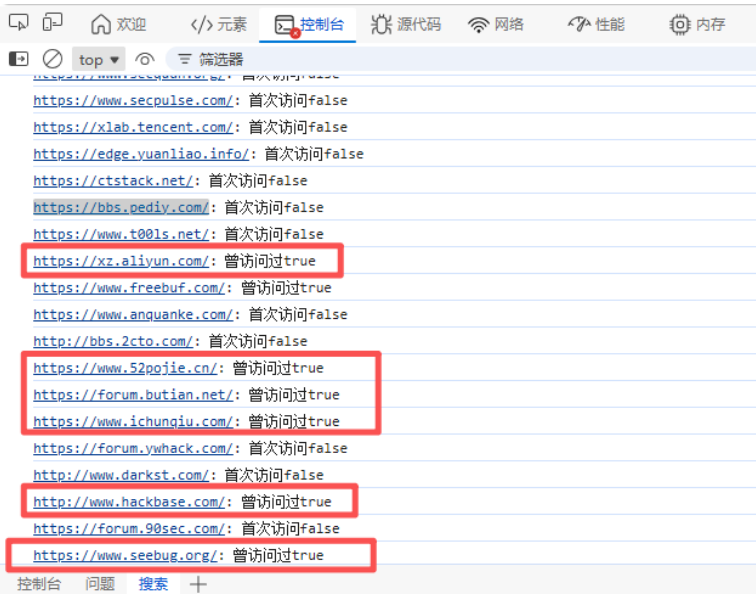


图 4.8 利用 localStorage 获取历史记录

这样就可以区分普通用户和高危用户了，对用户进行区分后进行主动防御配合之后的插件利用。

插件二：利用 H5 号码认证反制红队

场景模拟：假设攻击者使用手机运营商的网络开热点给电脑上网做渗透的情况下，可以利用运营商的接口去获取攻击者手机号，利用阿里云的 H5 号码认证服务可以无感获取攻击者的部分手机号。



图 4.9 利用 H5 号码认证反制红队

蜜罐后台已启用该插件，攻击者在运营商网络下访问蜜罐“企业管理系统”。



图 4.10 利用 H5 号码认证反制红队

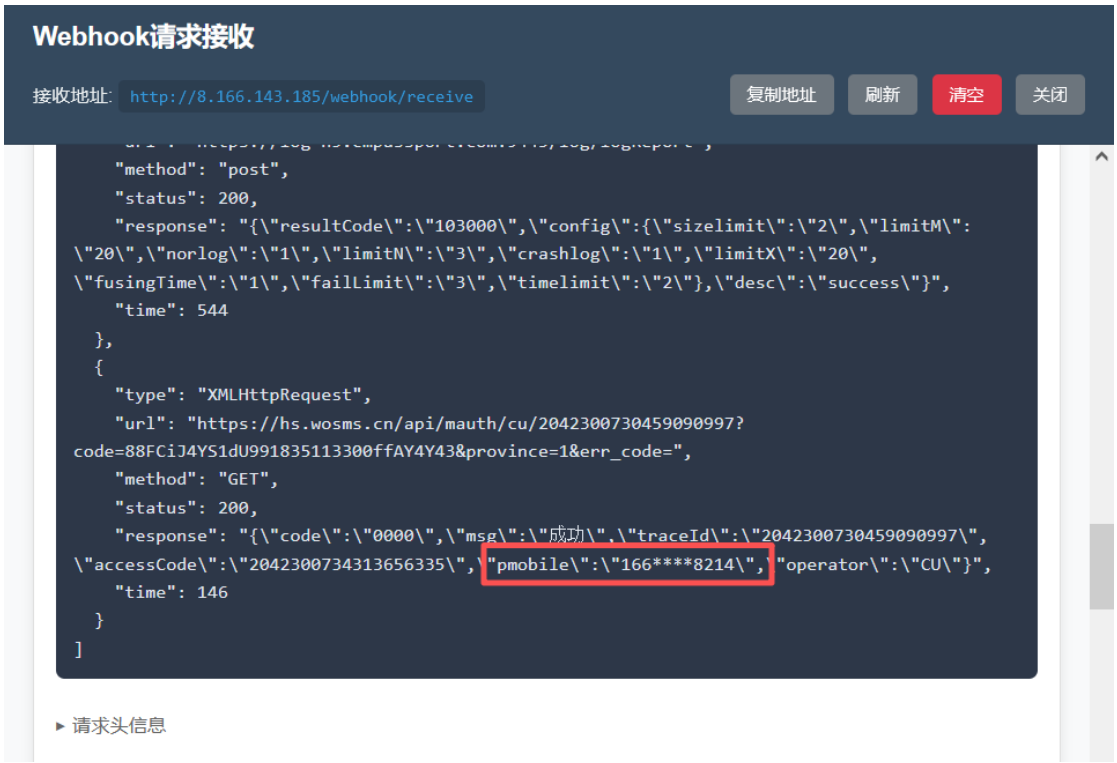


图 4.11 利用 H5 号码认证反制红队

在蜜罐后台就可以接收到带掩码的部分手机号，可以配合查号吧获取完整手机号。

手机号码中间四位查询

有很多网友遇到手机号码中间四位被隐去的情况，迫切希望通过手机号码前三位和后四位查询到中间四位号码。查号吧网站的数据比较全面、每月更新，使用下面的表单可以快速查询出中间被隐藏的4位号段并下载到本地。如果不知道省份和城市，可选择“不确定”。

166

海南

海口

8214

查询

共有60条符合查询条件，此页面仅展示15条。 [点击此处下载全部60条号段](#)

省份	市区	运营商	号段
海南	海口	联通	1660890****
海南	海口	联通	1660891****
海南	海口	联通	1660892****
海南	海口	联通	1660893****
海南	海口	联通	1660894****

图 4.12 利用 H5 号码认证反制红队

插件三：反制 VPS 漏扫基于无头浏览器技术

场景假设：当攻击者的 VPS 使用无头浏览器开发的扫描工具对“企业管理系统”蜜罐 进行扫描时，可以利用无头浏览器可以绕过 CORS 的限制功能，当用户访问 web 蜜罐时执行访问元数据操作，将内容转发到服务器保存。



图 4.13 反制 VPS 漏扫基于无头浏览器技术

蜜罐后台已启用该插件，攻击者在 VPS 扫描器访问蜜罐“企业管理系统”。

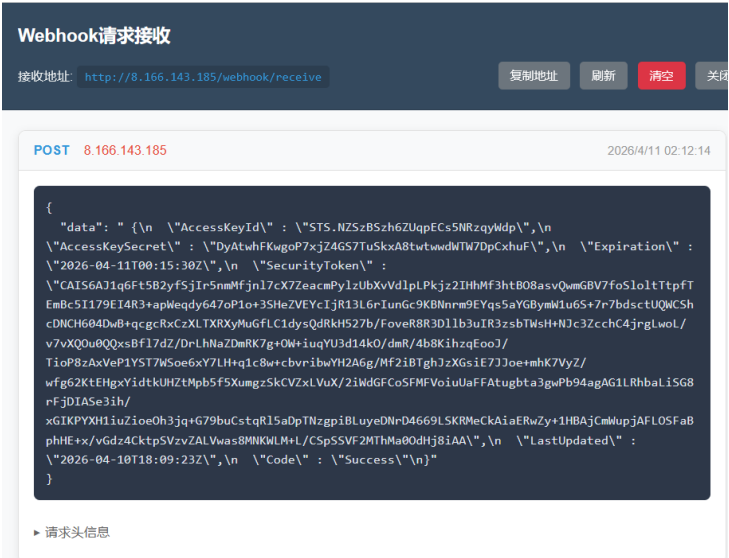


图 4.14 反制 VPS 漏扫基于无头浏览器技术

在蜜罐后台就可以接收到 VPS RAM 的临时凭证 AccessKeyId、AccessKeySecret、SecurityToken。可以利用这些凭证去接管攻击者的 VPS 云服务器。

插件四：win10 蓝屏反制

场景假设：当攻击者的系统没有更新使用的是 Windows 10 1709 及以上，那么就可以利用该漏洞进行蓝屏反制^[14]。



图 4.15 插件-win10 蓝屏反制

蜜罐后台已启用该插件，攻击者访问蜜罐“企业管理系统”会自动下载 html 文件到本地。

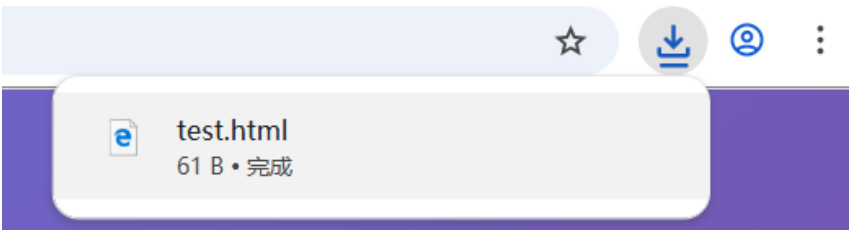


图 4.16 插件-win10 蓝屏反制

并且默认浏览器为 chrome 双击打开了 test.html 文件即可会触发蓝屏，或者如果攻击者的浏览器使用的是旧内核如 IE11 之类的对 file://限制会很宽松 无需下载文件访问网站即可触发蓝屏。



图 4.17 插件-win10 蓝屏反制

当使用 chrome 浏览器访问 成功蓝屏，可以配合 localStorage 获取的历史记录对高危用户使用。

4.3.4 XGPT 威胁分析智能体

XGPT 这个工具，本质上是一个用人工智能来搞威胁分析的助手，可以当成你个人的网络安全顾问。它里面整合了 DeepSeek 这个大语言模型，所以能理解并回答很多跟网络安全有关的问题。比如说，它能帮你分析那些从蜜罐里收集到的攻击数据。具体的情况可以参考图 4.18 里的展示。



图 4.18 XGPT 威胁分析智能体页面

XGPT 威胁分析智能体。具体来说，通过后台系统设置的系统提示词角色身份以及要做的事情，读取环境变量配置获取系统提示词后，将用户输入的内容包括但不限于 IP, Domain 等内容调用 DeepSeek 官方的 API 接口完成分析流程并输出详细分析报告。

```

01 处理 XGPT 威胁分析智能聊天请求
02 函数 HandleXGPChat(上下文 c)
03     1. 定义聊天请求结构体 chatReq
04     2. 绑定并校验前端 JSON 请求数据:
05         2.1 若数据绑定失败, 返回 400 错误"Invalid request"
06         2.2 若用户消息为空, 返回 400 错误"Message cannot be empty"
07     3. 从环境变量读取 DeepSeek API 密钥:
08         3.1 若密钥为空, 返回 500 错误"API key not configured"
09     4. 从环境变量读取 AI 系统提示词:
10         4.1 若提示词为空, 返回 500 错误"System prompt not "
11     5. 构造 DeepSeek API 请求结构体, 包含系统角色与用户消息
12     6. 将请求体序列化为 JSON:
13         6.1 若序列化失败, 返回 500 错误"Failed to marshal request"
14     7. 创建 HTTP POST 请求, 调用 DeepSeek 官方接口:
15         7.1 若请求创建失败, 返回 500 错误"Failed to create request"
16     8. 为请求添加 Bearer 认证头与 Content-Type 头
17     9. 发送 HTTP 请求, 获取 API 响应
18    10. 解析响应数据, 提取 AI 生成的威胁分析回复
19    11. 以 HTTP 200 状态, 将 AI 回复返回给前端
20 结束函数

```

伪代码 4.3.4 DeepSeek 接口调用实现代码核心流程

4.3.5 系统设置

后台系统设置用于配置 DeepSeek API Key、XGPT 威胁分析智能体系统提示词、登录账号密码、数据库密码。并且对敏感的信息如数据库密码与登录账号密码 password 等字段使用掩码遮盖显示如图 4.19 所示。

图 4.19 系统管理设置



图 4.20 系统管理设置

系统配置信息查询接口。具体来说，对环境变量中的 DeepSeek API Key、管理员账号、数据库连接信息，对敏感信息进行脱敏掩码处理后，以 JSON 格式返回给前端。

- 01 定义接口处理函数 HandleGetSettings，接收 Gin 上下文
- 02 1. 定义默认 AI 系统提示词 defaultPrompt，设定专家角色与能力列表
- 03 2. 初始化配置字典 settings，遍历读取各项系统配置
- 04 3. 对 DeepSeek API 密钥执行掩码处理（显示前 7 位+星号）
- 05 4. 对 AI 系统提示词：取环境变量值，无则用默认 prompt
- 06 5. 对管理员账号：取环境变量值，无则用默认“admin”
- 07 6. 对管理员密码：取环境变量值，无则用默认“admin123”，最终掩码显示
- 08 7. 对数据库连接信息：分别读取环境变量，无则用默认本地连接值
- 09 8. 对数据库密码：取环境变量值，无则用默认“root”，最终掩码显示
- 10 9. 调用 c.JSON()，以 HTTP 200 状态码，将脱敏后的配置返回给前端

伪代码 4.3.5 系统配置核心流程

第 5 章 系统测试

5.1 测试目的

目前，基于 Go Gin 框架的轻量化蜜罐平台已经完成了开发工作。接下来需要进行测试，对这个软件的可靠性进行验证检测软件是否可以正常工作，后台接口的功能是否正常调用，在进行压力并发性能测试界面显示是否正常等。

5.2 后台管理功能测试

后台管理功能测试是对系统的管理员后台功能进行测试，包括攻击者信息管理、插件管理、系统设置等功能。测试步骤如下：

表 5.1 后台管理功能测试用例

测试用例	功能测试	测试用例描述	预期结果	实际结果	测试状态
001	登录测试	测试管理员登录功能，验证是否能够正确登录管理员后台。	登录成功	登录成功	通过
002	攻击者信息管理测试	测试攻击者信息的查看、刷新和导出功能，验证是否能够正确地查看和管理攻击者信息。	查询成功	查询成功	通过
003	插件管理测试	测试插件的创建、更新、删除和启用/禁用功能，验证是否能够正确地管理插件。	添加、修改、删除插件成功	添加、修改、删除插件成功	通过

004	AI 威胁分析测试	测试威胁分析智能体的功能，验证是否能够正确地分析威胁情报。	验证威胁情报 IP 成功	验证威胁情报 IP 成功	通过
005	系统设置测试	测试系统设置的保存和获取功能，验证是否能够正确地配置系统。	添加、修改、删除配置成功	添加、修改、删除配置成功	通过

5.3 性能测试

性能测试，简单来说就是看看系统在很多人同时用的时候表现怎么样，比如响应时间、吞吐量这些指标。具体做起来呢，首先得把测试环境准备好，服务器和数据库都得搭好。然后要写一些脚本，这些脚本的作用是模拟出大量用户同时访问的情况。接着就是执行这些脚本了，让它们真正跑起来去发送请求。最后一步很关键，要把测试过程中产生的各种数据收集起来进行分析，像响应时间和资源利用率这些数据都得拿到手。

```

01 初始化测试配置：设置 100 并发数、测试 URL、登录数据
02 定义测试函数 test_request():
03     1. 记录请求开始时间
04     2. 发送 POST 请求获取响应
05     3. 计算耗时，存入响应时间列表
06     4. 打印单次请求耗时与状态码
07 主流程：
08     1. 循环创建 100 个线程，启动并发执行 test_request()
09     2. 调用 thread.join() 等待所有线程完成
10     3. 计算响应时间的平均值、最大值、最小值
11     4. 输出性能统计报告

```

伪代码 5.3 性能测试核心流程


```
Response time: 0.5564s, Status code: 401
Response time: 0.5462s, Status code: 401
Response time: 0.5457s, Status code: 401
Response time: 0.5430s, Status code: 401
Response time: 0.5483s, Status code: 401
Response time: 0.5473s, Status code: 401
Response time: 0.5431s, Status code: 401
Response time: 0.5442s, Status code: 401
Response time: 0.5504s, Status code: 401
Response time: 0.5378s, Status code: 401
Response time: 0.6995s, Status code: 401
Response time: 0.5462s, Status code: 401
Response time: 0.5368s, Status code: 401
Response time: 0.7130s, Status code: 401
Response time: 0.5337s, Status code: 401
Response time: 0.5641s, Status code: 401
Response time: 0.5660s, Status code: 401
Response time: 0.5661s, Status code: 401
Response time: 0.5667s, Status code: 401
Response time: 0.5770s, Status code: 401
Response time: 0.5651s, Status code: 401
Response time: 0.5574s, Status code: 401
Response time: 0.5658s, Status code: 401
Response time: 0.5684s, Status code: 401
Response time: 0.5637s, Status code: 401
Response time: 0.5653s, Status code: 401
Average response time: 0.5122s
Max response time: 0.7130s
Min response time: 0.2669s
```

图 5.1 性能测试效果

功能测试：各项功能目前都处于正常运转状态，像是蜜罐的登录页面、攻击者信息的收集模块、插件管理界面以及管理员后台这些部分，都能顺利使用。

性能测试：系统在高并发的时候，表现还是可以的。我们写了个 Python 脚本，模拟了 100 个同时发起的请求，去压那个蜜罐的登录接口。下面就是测试出来的结果。

平均响应时间：0.5122 秒

最大响应时间：0.7130 秒

最小响应时间：0.2669 秒

并发请求数：100 个

测试结果状态码：所有请求均返回 401 状态码（未授权），符合蜜罐系统返回虚假登录失败的预期行为

测试下来，系统在同时处理一百个并发请求的时候，表现是稳定的。响应时间呢，也都在可以接受的范围内，没有出现请求失败或者超时的情况。所有那些攻击尝试都被正确记录下来了，并且系统返回了预期的虚假响应。这证明了蜜罐系统的稳定性和可靠性。

5.4 测试结果

从测试来看，基本都实现了预期的效果，算是达到系统的基本要求吧。不过要是和那些已经很成熟的系统比一比的话，还是能看出一些差距的。后续肯定得继续跟进下去，发现问题就及时处理掉，让整个系统的功能和设计都能一点点完善起来。

第 6 章 结论

融合溯源反制的轻量化诱捕型蜜罐系统作为一款轻量化蜜罐能够模拟真实的 web 登录界面来吸引攻击者并且能够记录和捕获攻击行为特征能够助力蓝队安全人员及时的发现威胁并做出响应。系统采用模块化设计支持动态插件的扩展来增强蜜罐的能力边界在定制化和扩展性方面发挥不错，并且还集成 DeepSeek 的威胁分析 Agent 能够处理分析溯源攻击者。

这个系统为网络安全防御提供了一个有效手段随着技术的发展未来 Web 蜜罐在网络防御中的作用预计会更加重要。

参考文献

- [1] 中国工业互联网安全态势报告(2018 年)[J]. 中国信息安全, 2019, (06): 62-65.
- [2] 石乐义, 李阳, 马猛飞. 蜜罐技术研究新进展[J]. 电子与信息学报, 2019, 41(02): 498-508.
- [3] 石乐义, 姜蓝蓝, 贾春福, 等. 蜜罐诱骗防御机理的博弈理论分析[J]. 电子与信息学报, 2012, 34(06): 1420-1424.
- [4] 诸葛建伟, 唐勇, 韩心慧, 等. 蜜罐技术研究与应用进展[J]. 软件学报, 2013, 24(04): 825-842.
- [5] 中国信息通信研究院安全研究所(CAICT). 国内威胁诱捕(蜜罐)类产品研究与测试报告. [EB/OL]. <https://www.sdyanbao.com/detail/188321>
- [6] 永信至诚. 蜜罐护卫模式: 七蜜体矩阵技术白皮书. [EB/OL]. https://www.integritytech.com.cn/html/News/News_614_1.html
- [7] 北京知道创宇信息技术有限公司. 创宇蜜罐威胁诱捕与溯源系统白皮书 v1.5. [EB/OL]. [2021-01-20]. <https://netmarket.oss-cn-hangzhou.aliyuncs.com/02486fecf63c47299ef825055637936b.pdf>
- [8] 奇安信网神信息技术(北京)股份有限公司. 奇安信网神攻击诱捕系统产品白皮书 V1.0.2.1. [EB/OL]. [2022-06-20]. [https://www.legendsec.com/attachment/220622/攻击诱捕系统 V1.0.2.1 -产品白皮书 V1.1\(公开版\).pdf](https://www.legendsec.com/attachment/220622/攻击诱捕系统V1.0.2.1-产品白皮书V1.1(公开版).pdf)
- [9] 猿媛之家, 穆旭东, 谭庆丰, 等. Go 程序开发实战宝典[M]. 机械工业出版社: 202301: 337.
- [10] 潘梦双, 郭秉昊, 张思缘, 等. 基于 Honeypot 技术的网络入侵检测系统[J]. 工业控制计算机, 2025, 38(04): 109-110.
- [11] HFish 开源社区. HFish——新一代轻量化蜜罐平台 [EB/OL]. <https://hfish.net/>
- [12] 长亭科技. 主动威胁欺骗防御系统(谛听) D-Sensor [EB/OL]. <https://www.chaitin.cn/dsensor>.
- [13] DecoyMini. DecoyMini·吉星(智能仿真与攻击诱捕系统) [EB/OL]. <http://www.decoyit.com/product/0-95.html>.
- [14] Microsoft. Windows crash when navigate \Device\condrv [EB/OL]. <https://learn.microsoft.com/en-us/answers/questions/235907/windows-crash-when-navigate-globalrootdevicecondrv>.
- [15] 张楠. 基于 BIM+WebGL 技术的结构有限元计算与数据交互方法研究[D]. 大连理工大学, 2024. DOI: 10.26991/d.cnki.gdllu.2024.004419.
- [16] Gin 开发团队. Gin 框架官方文档 [EB/OL]. (2026-04-03) [2026-04-13]. <https://gin-gonic.com/zh-cn/docs/>.

致 谢

本论文的研究围绕基于 Go Gin 框架的系统开发展开。首先要感谢我的导师黄鹏，他在整个过程中提供了关键的学术指导和支持，不仅给予了宝贵的资源与意见，那种亲切的关心和细致的指点也让我有信心把这项研究做下去。他一直鼓励我，还贡献了不少具体的设计思路。在此，我向他表达真诚的谢意和敬意。

另外也要感谢所有参与了系统测试和评估的用户们，正是他们给出的那些很有价值的反馈，才让整个系统的设计与开发得以进一步完善。写到这儿，论文快要完成了，心情其实挺难平静的。从刚接触这个课题一直到论文最终完成，中间经历了挺多，有过焦虑和烦恼的时刻，也感受到来自同学、老师、朋友们的关心与热情，当然还有那种夹杂着成就感和辛酸的复杂体会。

最后我想再一次衷心感谢所有给予过我关心和帮助的老师、同学们。